

■ ■ AWS INTERVIEW BIBLE

Complete Preparation Guide — Basics to Advanced

EC2 · S3 · IAM · VPC · RDS · Lambda · ECS · EKS · CloudFormation

Route53 · CloudWatch · SQS · SNS · DynamoDB · Networking · Security

■ ■ ■ ■ Questions · Production Scenarios · Interview Traps · Cheat Sheets

TABLE OF CONTENTS

1. IAM — Identity and Access Management
2. EC2 — Elastic Compute Cloud
3. S3 — Simple Storage Service
4. VPC — Virtual Private Cloud & Networking
5. RDS & Aurora — Managed Databases
6. DynamoDB — NoSQL Database
7. Lambda & Serverless
8. ECS & EKS — Containers
9. CloudFormation & IaC
10. Route 53 — DNS & Load Balancing
11. CloudWatch, CloudTrail & Monitoring
12. SQS, SNS & Event-Driven Architecture
13. Storage — EBS · EFS · Glacier
14. Security, KMS & Compliance
15. Cost Optimization & Well-Architected
16. Top 60 Tricky Interview Q&A;
17. Production Scenarios & Troubleshooting
18. AWS Cheat Sheets

Chapter 1: IAM — Identity & Access Management

Policies · Roles · Users · MFA · STS

What is IAM?

IAM is AWS's centralized authorization system. It controls WHO can do WHAT on WHICH resources. IAM is global (not region-specific).

Core Components

Component	Description	Key Point
User	Represents a person or app	Long-term credentials
Group	Collection of users sharing policy	No nested groups
Role	Temporary identity assumed by services/users	No permanent credentials
Policy	JSON document defining permissions	Attached to users/groups/roles
STS	Security Token Service — issues temp credentials	Used with AssumeRole

Policy Types

Type	Who Attaches	Use Case
Identity-based	User/Group/Role	Grant user permissions
Resource-based	AWS Resource (S3, SQS...)	Cross-account access
Permission Boundary	User/Role	Maximum permission cap
SCP (Service Control Policy)	AWS Organization	Guard rails for accounts
Session Policy	Passed during AssumeRole	Restrict temp session

IAM Policy Evaluation Logic

DENY always wins. Evaluation order: 1) Explicit Deny → 2) SCP → 3) Resource Policy → 4) Permission Boundary → 5) Identity Policy → 6) Session Policy. Default is IMPLICIT DENY if no allow found.

Interview Q&A; — IAM

★★★★★

■ What is the difference between a Role and a User?

■ A User has permanent credentials (username/password, access keys). A Role has no credentials — it issues temporary credentials via STS when assumed. Roles are used by services (EC2, Lambda), other accounts, or federated users. Prefer roles over long-term access keys.

★★★★★

■ Can an IAM policy DENY override an ALLOW?

■ Yes. Explicit Deny always overrides any Allow, regardless of which policy it comes from. This is the most important evaluation rule in IAM.

★★★★■

■ What is a Permission Boundary?

■ A Permission Boundary is an IAM managed policy that sets the maximum permissions an identity policy can grant. Even if the identity policy allows an action, the boundary must also allow it. Used when delegating permission management to developers — they can't grant themselves more than the boundary.

★★★★★

■ What is AssumeRole? How does cross-account access work?

■ AssumeRole calls STS to get temporary credentials (access key, secret, token). For cross-account: Account A creates a role with a trust policy allowing Account B. An entity in Account B calls sts:AssumeRole — STS returns temp creds valid for 1–12 hours. No permanent keys shared.

■■ **TRAP: Confusing resource-based policies with identity-based. S3 bucket policy is resource-based. If both exist, AWS uses a union — but explicit Deny still wins.**

■ **TIP: Always enable MFA for root account and IAM users with console access. Never use root for day-to-day work.**

Chapter 2: EC2 — Elastic Compute Cloud

Instances · AMI · EBS · ASG · ELB · Placement Groups

Instance Purchasing Options

Type	Discount vs On-Demand	Best For
On-Demand	0%	Unpredictable short workloads
Reserved (1 or 3 yr)	Up to 72%	Steady-state production apps
Savings Plans	Up to 72%	Flexible compute commitment
Spot	Up to 90%	Fault-tolerant batch jobs
Dedicated Host	Varies	BYOL licensing, compliance
Dedicated Instance	Varies	Physical isolation required

EC2 Placement Groups

Type	What It Does	Use Case
Cluster	All instances on same rack	Low latency HPC, big data
Spread	Each instance on different rack/AZ	Critical HA instances (max 7/AZ)
Partition	Groups of instances on separate racks	Kafka, Cassandra, HDFS

Auto Scaling Group (ASG) Key Concepts

- Launch Template: defines AMI, instance type, SGs, user-data — versioned.
- Scaling Policies: Target Tracking (keep CPU at 60%), Step Scaling, Scheduled.
- Cooldown: default 300s — prevents rapid scale up/down thrashing.
- Lifecycle Hooks: pause instance at launch/terminate to run custom scripts.
- Health Checks: EC2 status checks OR ELB health checks (more accurate).

Interview Q&A; — EC2

★★★★★

■ What happens when a Spot Instance is interrupted?

■ AWS gives a 2-minute warning via instance metadata and EventBridge. The instance is then terminated, stopped, or hibernated based on your configuration. Best practice: use Spot with Auto Scaling mixed instance pools to maintain capacity. Never run stateful apps on a single Spot instance.

★★★★★

■ Difference between stopping and terminating an EC2 instance?

■ Stop: instance shuts down, EBS root volume persists, no charge for compute. Terminate: instance and root EBS (if DeleteOnTermination=true) are deleted permanently. Instance store volumes are ALWAYS lost on stop or terminate.

★★★★■

■ What is EC2 User Data?

■ A script that runs once at first boot (as root). Used to install packages, configure services, or pull code. Accessible via <http://169.254.169.254/latest/user-data>. For repeatable execution, use cloud-init or SSM Run Command.

★★★★★

■ EBS vs Instance Store?

■ EBS: network-attached, persistent, survives stop/start, can be encrypted, snapshotted to S3. Instance Store: physically attached NVMe/SSD, ephemeral — lost on stop/terminate/host failure. Instance Store gives higher IOPS but zero durability. Use it for temp caches, scratch space.

■■ TRAP: Many candidates forget: Reserved Instances are a billing concept, not a physical reservation. You still launch On-Demand EC2 — AWS applies the discount automatically.

Chapter 3: S3 — Simple Storage Service

Storage Classes · Versioning · Replication · Security · Lifecycle

S3 Storage Classes

Class	Availability	Min Duration	Use Case
Standard	99.99%	None	Frequently accessed
Standard-IA	99.9%	30d	Infrequent, fast retrieval
One Zone-IA	99.5%	30d	Recreatable infrequent data
Intelligent-Tiering	99.9%	None	Unknown access pattern
Glacier Instant	99.9%	90d	Archive, ms retrieval
Glacier Flexible	99.99%	90d	Archive, hours retrieval
Glacier Deep Archive	99.99%	180d	7-year retention, 12h retrieval

S3 Security Controls

- Bucket Policy (resource-based): cross-account or public access grants.
- ACLs: legacy — avoid. Use bucket policies instead.
- Block Public Access (BPA): account or bucket level — always enable on production.
- Encryption: SSE-S3 (AWS manages keys), SSE-KMS (you control keys), SSE-C (you provide key per request), CSE (client-side).
- VPC Endpoint (Gateway): S3 traffic stays within AWS network — no internet.

Interview Q&A; — S3

★★★★★

■ What is S3 Versioning and why use it?

■ Versioning maintains all versions of an object including overwrites and deletes. A delete only adds a Delete Marker — the object isn't gone. You can restore previous versions. Pre-requisite for Cross-Region Replication. Protects against accidental deletions. Note: you pay for storage of all versions.

★★★★★

■ What is a Pre-Signed URL?

■ A time-limited URL that grants temporary access to a private S3 object. Generated by an IAM entity — the URL inherits that entity's permissions. Valid up to 7 days (URL signer) or 12 hours (IAM role). Used for secure temporary downloads/uploads without exposing credentials.

★★★★■

■ S3 Replication — CRR vs SRR?

■ CRR (Cross-Region Replication): replicates to a bucket in a different region. Use for compliance, lower latency, or DR. SRR (Same-Region Replication): replicates within same region — useful for log aggregation or dev/prod separation. Both require Versioning on source AND destination. Only new objects replicate after enabling — use S3 Batch Operations for existing objects.

■■ **TRAP: S3 is NOT a file system — it's object storage. Max object size is 5TB. Objects >5GB must use Multipart Upload. There is no 'rename' in S3 — it's a copy + delete.**

Chapter 4: VPC — Networking & Security

Subnets · SGs · NACLs · NAT · VPN · Peering · PrivateLink

VPC Fundamentals

- VPC: isolated virtual network in AWS, spans all AZs in a region.
- Subnet: subdivision of VPC CIDR, tied to ONE AZ. Public subnet has route to IGW.
- Internet Gateway (IGW): allows internet access for public subnets.
- NAT Gateway: lets private subnet instances reach internet. Managed, HA per AZ.
- Route Table: rules that direct traffic from subnet. Each subnet has one.

Security Group vs NACL

Feature	Security Group	NACL
Level	Instance (ENI)	Subnet
State	Stateful	Stateless
Rules	Allow only	Allow + Deny
Rule order	All evaluated	Numbered, first match wins
Default	All outbound allowed	All traffic allowed (default NACL)
Use case	App-level firewall	Subnet-level broad blocks

Connectivity Options

Option	What It Is	Key Limit
VPC Peering	Direct VPC-to-VPC connection	Not transitive
Transit Gateway	Hub-and-spoke for many VPCs	Transitive routing possible
Site-to-Site VPN	Encrypted tunnel over internet	~1.25 Gbps per tunnel
Direct Connect	Dedicated private line to AWS	Lower latency, higher cost
PrivateLink	Expose service privately via ENI	No VPC peering needed

Interview Q&A; — VPC

★★★★★

■ Why is Security Group stateful but NACL stateless?

■ SG tracks connection state — if you allow inbound port 80, the return traffic is automatically allowed. NACL does not track state — you must explicitly allow both inbound AND outbound for each port. Forgetting the ephemeral port range (1024-65535) in NACL outbound rules is a classic mistake.

★★★★★

■ What is VPC Peering and its limitations?

■ Peering creates a direct private connection between two VPCs (same or different account/region). Traffic uses AWS backbone — never public internet. Key limitations: NOT transitive (A peers B, B peers C — A cannot reach C via B), no overlapping CIDRs allowed. For many VPCs, use Transit Gateway instead.

★★★★■

■ Difference between NAT Gateway and NAT Instance?

■ NAT Gateway: AWS-managed, HA within AZ, no patching, scales to 45 Gbps, costs more. NAT Instance: self-managed EC2, single point of failure, you maintain it, cheaper, can use as bastion. Always prefer NAT Gateway in production. Deploy one per AZ for true HA.

■■ **TRAP: VPC CIDR cannot be changed after creation. Plan IP ranges carefully. Overlapping CIDRs block VPC Peering and Transit Gateway attachments.**

Chapter 5: RDS & Aurora — Managed Databases

Multi-AZ · Read Replicas · Aurora · Backups · Encryption

RDS Key Concepts

Feature	Multi-AZ	Read Replica
Purpose	High Availability	Read Scalability / DR
Replication	Synchronous	Asynchronous
Failover	Automatic (60-120s)	Manual promotion
Readable	No (standby not accessible)	Yes
Cross-region	No	Yes
Use for	Production HA	Analytics, reporting, DR

Aurora vs RDS

Feature	Aurora	RDS MySQL/PostgreSQL
Storage	Auto-scales to 128TB	Manual up to 64TB
Replicas	Up to 15 read replicas	Up to 5
Failover	30s (sub-minute)	60–120s
Cost	~20% higher	Lower
Global DB	Yes — cross-region	Only via read replicas
Serverless v2	Yes	No

Interview Q&A; — RDS

★★★★★

■ What happens during an RDS Multi-AZ failover?

■ AWS automatically switches DNS to the standby replica in ~60-120 seconds. Your application must handle connection retries — the endpoint DNS changes, not the hostname. Triggers: AZ failure, instance failure, DB instance class change, OS patching. Standby is NOT readable during normal ops — it's purely for HA.

★★★★■

■ How does Aurora Global Database work?

■ One primary region handles reads/writes. Up to 5 secondary regions replicate with <1 second lag. In a disaster, you can promote a secondary region to primary in <1 minute. Replication uses dedicated replication infrastructure — not MySQL binlog.

■■ **TRAP: Read Replicas are NOT the same as Multi-AZ. Replicas add read capacity; Multi-AZ adds availability. You can have both simultaneously.**

Chapter 6: DynamoDB — NoSQL at Scale

Partition Key · GSI · LSI · Streams · DAX · Capacity

Core Concepts

- Partition Key (PK): mandatory. Must be unique if used alone. Distributed by hash.
- Sort Key (SK): optional. Together with PK forms composite key. Enables range queries.
- GSI (Global Secondary Index): different PK+SK, can span all partitions. Eventual consistency.
- LSI (Local Secondary Index): same PK, different SK. Must be created at table creation. Strongly consistent reads possible.
- DAX: in-memory cache in front of DynamoDB. Microsecond latency. API-compatible.
- DynamoDB Streams: change log of item-level changes. Powers Lambda triggers.

Capacity Modes

Mode	How It Works	Best For
Provisioned	You specify RCU/WCU. Use Auto Scaling.	Predictable traffic
On-Demand	Pay per request. No planning.	Spiky/unknown traffic

1 RCU = 1 strongly consistent read/s for items up to 4KB (or 2 eventually consistent reads). 1 WCU = 1 write/s for items up to 1KB. Larger items consume proportionally more capacity.

Interview Q&A; — DynamoDB

★★★★★

■ What causes hot partition issues in DynamoDB?

■ Poor partition key design. If many requests target the same partition key value (e.g., using 'status' as PK with values 'active'/'inactive'), one partition gets all the traffic while others sit idle. Solution: use high-cardinality PKs (user IDs, UUIDs), or add a random suffix to distribute load (write sharding). DAX also helps on the read side.

★★★★■

■ When would you choose DynamoDB over RDS?

■ DynamoDB: when you need single-digit millisecond latency at any scale, serverless architecture, simple key-value or document access patterns, and no complex joins or transactions (though DynamoDB Transactions exist for limited cases). RDS: complex relational queries, ad-hoc SQL, strict ACID requirements across many tables.

■■ **TRAP: DynamoDB max item size is 400KB. Storing large objects in DynamoDB is wrong — store the object in S3 and put the S3 key in DynamoDB.**

Chapter 7: Lambda & Serverless

Triggers · Concurrency · Cold Start · Layers · Destinations

Lambda Key Facts

- Max execution time: 15 minutes.
- Max memory: 10GB (vCPU scales proportionally with memory).
- Deployment package: 50MB zipped, 250MB unzipped (use Layers for larger deps).
- Concurrency: 1000 per region default (soft limit). Each invocation = 1 unit.
- Reserved Concurrency: caps a function's max concurrent executions.
- Provisioned Concurrency: pre-warms instances to eliminate cold starts.

Event Source Mapping vs Invocation

Method	Example Sources	Key Behavior
Synchronous	API Gateway, ALB, Cognito	Caller waits for response
Asynchronous	S3, SNS, EventBridge	Lambda retries 2x on failure
Poll-based	SQS, Kinesis, DynamoDB Streams	Lambda polls, batch processes

Interview Q&A; — Lambda

★★★★★

■ What is a Lambda cold start and how do you reduce it?

■ Cold start: when AWS needs to initialize a new execution environment — download code, start runtime, run init code. Takes 100ms–3s depending on runtime and package size. Reduction: use Provisioned Concurrency (pre-warm), smaller deployment packages, compiled runtimes (Go/Rust) over interpreted (Python/Node), avoid VPC if not needed (VPC adds ~1s), keep init code outside handler.

★★★★■

■ How does Lambda handle SQS failures?

■ Lambda polls SQS in batches. If processing fails and the function throws, Lambda retries the entire batch until the message visibility timeout expires, then the message goes to DLQ if configured. Set `bisect_batch_on_function_error=true` to split failed batches, isolating the bad message faster. Always configure a DLQ on SQS for unprocessable messages.

■■ **TRAP: Lambda functions in a VPC no longer have internet access unless the VPC has a NAT Gateway. Forgetting this causes silent timeouts connecting to public APIs.**

Chapter 8: ECS & EKS — Container Orchestration

Fargate · Task Definitions · Services · Kubernetes on AWS

ECS vs EKS vs Fargate

Feature	ECS	EKS	Fargate
Orchestration	AWS proprietary	Kubernetes	N/A (launch type)
Control plane	AWS managed	AWS managed	Fully serverless
Learning curve	Low	High (K8s knowledge)	Low
EC2 control	Yes (EC2 launch type)	Yes (node groups)	No — no servers
Cost	No cluster fee	\$0.10/hr cluster	Pay per vCPU/mem
Use when	AWS-native teams	K8s portability need	No infra management

ECS Key Concepts

- Task Definition: blueprint — image, CPU, memory, port, IAM role, env vars. Versioned.
- Task: running instance of a Task Definition.
- Service: ensures N tasks are always running. Integrates with ALB, Auto Scaling.
- Task Role: IAM role for containers (e.g., S3 access). Different from Execution Role.
- Execution Role: IAM role for ECS agent — pull ECR image, write CloudWatch logs.

Interview Q&A; — ECS/EKS

★★★★★

■ What is the difference between Task Role and Execution Role in ECS?

■ Execution Role: used by the ECS agent/Fargate to pull container images from ECR and send logs to CloudWatch.
Task Role: used by the application code running inside the container to call AWS services (e.g., read S3, write DynamoDB). Common mistake: putting app permissions in Execution Role — they must be in Task Role.

★★★★■

■ How do you do zero-downtime deployments in ECS?

■ Use rolling update deployment with minimum healthy percent (e.g., 50%) and maximum percent (200%). ECS launches new tasks before draining old ones. Pair with ALB health checks — traffic shifts only after new tasks pass health checks. For more control, use Blue/Green deployment with CodeDeploy.

Chapter 9: CloudFormation & IaC

Stacks · ChangeSet · Drift · Cross-Stack · SAM

CloudFormation Template Structure

Section	Required?	Purpose
AWSTemplateFormatVersion	No	Template version (2010-09-09)
Description	No	Human-readable description
Parameters	No	Input values at deploy time
Mappings	No	Static lookup tables (AMI IDs by region)
Conditions	No	Conditional resource creation
Resources	YES	AWS resources to create
Outputs	No	Export values to other stacks

CloudFormation vs Terraform

Feature	CloudFormation	Terraform
Language	YAML/JSON	HCL
Provider	AWS only	Multi-cloud
State	Managed by AWS	State file (S3+DynamoDB)
Rollback	Automatic on failure	Manual
Drift detection	Built-in	terraform plan
Learning curve	Medium	Medium

Interview Q&A; — CloudFormation

★★★★★

■ What is a ChangeSet and why use it?

■ A ChangeSet previews exactly what CloudFormation will create, modify, or delete before execution — like a dry-run. Critical for production: you review the changes, check for unexpected deletes (e.g., recreation of a stateful resource), then execute if safe. Always use ChangeSets in production instead of direct stack updates.

★★★★■

■ What are Cross-Stack References?

■ Stack A exports a value (Outputs with Export Name). Stack B imports it using Fn::ImportValue. This allows loose coupling between stacks — e.g., network stack exports VPC ID, app stack imports it. You cannot delete Stack A while Stack B references its exports.

■■ **TRAP: CloudFormation has a 500-resource limit per stack. For large architectures, use nested stacks or multiple stacks with cross-stack references.**

Chapter 10: Route 53 & Load Balancing

Routing Policies · Health Checks · ALB · NLB · CLB

Route 53 Routing Policies

Policy	How It Works	Use Case
Simple	Single resource	Basic setup
Weighted	Split traffic by %	A/B testing, gradual rollout
Latency	Route to lowest-latency region	Multi-region performance
Failover	Primary/secondary based on health	DR active-passive
Geolocation	Route by user's country/continent	Content localization, compliance
Geoproximity	Route by distance + bias	Traffic shifting between regions
Multi-Value	Return multiple IPs (health checked)	Client-side load balancing

ALB vs NLB vs CLB

Feature	ALB	NLB	CLB
OSI Layer	7 (HTTP/HTTPS)	4 (TCP/UDP/TLS)	4/7 (Legacy)
Protocols	HTTP, HTTPS, gRPC	TCP, UDP, TLS	HTTP, TCP
Static IP	No (use NLB)	Yes (per AZ)	No
Performance	High	Ultra-high (<1ms)	Basic
Rules	Path/host/header	Port only	Basic
Use case	Microservices, API	Low-latency, gaming	Legacy only

Interview Q&A; — Route 53 & ELB

★★★★★

■ What is an Alias Record vs CNAME in Route 53?

■ CNAME: maps one domain to another — cannot be used at zone apex (root domain). Alias: Route 53-specific, maps domain to AWS resource (ALB, CloudFront, S3 website). Can be used at apex. No TTL charge. Always prefer Alias for AWS resources.

★★★★■

■ How does ALB sticky sessions work?

■ ALB sets a cookie (AWSALB) that binds a client to a specific target for a configured duration. Duration-based (ALB manages) or application-based (your app sets the cookie). Risk: uneven load distribution if some sessions are very long. Use carefully — stateless design is better.

Chapter 11: CloudWatch, CloudTrail & Monitoring

Metrics · Alarms · Logs · Events · X-Ray

CloudWatch vs CloudTrail

Feature	CloudWatch	CloudTrail
Purpose	Performance monitoring & logs	API call audit trail
What it tracks	Metrics, logs, events	Who did what, when, from where
Retention	Metrics: 15mo; Logs: configurable	90d default; S3 for long-term
Use case	Alarms, dashboards, debugging	Security, compliance, forensics
Real-time	Yes (1-min or high-resolution)	~15 min delivery to S3

Key CloudWatch Concepts

- Namespaces: container for metrics (AWS/EC2, AWS/RDS, custom/MyApp).
- Dimensions: key-value pairs that identify a metric (InstanceId, FunctionName).
- Custom Metrics: push from your app via PutMetricData API. Resolution: 1min or 1sec (high-res).
- Log Insights: query CloudWatch Logs with SQL-like syntax. Fast ad-hoc analysis.
- Contributor Insights: identifies top N contributors (heavy hitters) in log data.
- EventBridge: successor to CloudWatch Events. Route events to Lambda, SQS, Step Functions.

Interview Q&A; — Monitoring

★★★★★

■ How do you monitor EC2 memory and disk usage?

■ By default, CloudWatch does NOT collect memory or disk metrics — these are inside the OS, not the hypervisor. You must install the CloudWatch Agent on the instance, configure it to collect `mem_used_percent` and `disk_used_percent`, and push them as custom metrics. Then create alarms on those metrics.

★★★★■

■ What is the difference between CloudWatch Alarms states?

■ OK: metric is within threshold. ALARM: metric has breached threshold. INSUFFICIENT_DATA: not enough data points yet (often at startup). Alarm actions can trigger: SNS notification, Auto Scaling action, EC2 action (stop/reboot/terminate).

Chapter 12: SQS, SNS & Event-Driven Architecture

Queues · Topics · Fan-out · DLQ · FIFO

SQS vs SNS vs EventBridge

Feature	SQS	SNS	EventBridge
Type	Queue (pull)	Topic (push)	Event bus
Consumers	One consumer per msg	Multiple subscribers	Multiple targets with rules
Retention	Up to 14 days	No retention	24h retry with archive
Ordering	FIFO queue option	No	No
Filtering	No	Subscription filter policy	Event pattern rules
Use case	Decouple producer/consumer	Fan-out notifications	Event routing between services

SQS Key Concepts

- Visibility Timeout: message hidden from other consumers while being processed (default 30s, max 12h).
- Message Retention: 1 min to 14 days (default 4 days).
- Long Polling: consumer waits up to 20s for messages — reduces API calls and cost.
- Dead Letter Queue (DLQ): receives messages that fail processing after maxReceiveCount.
- FIFO Queue: exactly-once processing, strict ordering. 300 TPS (3000 with batching).

Interview Q&A; — SQS/SNS

★★★★★

■ What happens if a consumer crashes while processing an SQS message?

■ The message becomes visible again after the visibility timeout expires. Another consumer can then pick it up. If this happens repeatedly (maxReceiveCount exceeded), the message moves to the DLQ. Best practice: set visibility timeout > your max processing time, configure DLQ, and monitor DLQ depth with CloudWatch alarm.

★★★★★

■ What is the SNS Fan-out pattern?

■ SNS publishes one message to a topic. Multiple SQS queues subscribe to the topic — each gets a copy. This decouples producers from consumers and allows parallel processing by different services. Classic pattern: S3 event → SNS topic → fan-out to SQS queues for different processors.

Chapter 13: Storage — EBS · EFS · FSx · Glacier

Volume Types · Snapshots · Shared Storage

EBS Volume Types

Type	IOPS	Use Case
gp3 (SSD)	Up to 16,000 IOPS	General purpose — recommended default
gp2 (SSD)	Up to 16,000 IOPS	General purpose (legacy, gp3 is better)
io2 Block Express	Up to 256,000	Mission-critical databases (Oracle, SAP)
io1 (SSD)	Up to 64,000 IOPS	High-performance databases
st1 (HDD)	Throughput optimized	Big data, log processing
sc1 (HDD)	Cold HDD	Infrequently accessed, lowest cost

EBS vs EFS vs S3

Feature	EBS	EFS	S3
Type	Block	File (NFS)	Object
Access	Single EC2 (or Multi-attach io1/io2)	Multiple EC2 across AZs	Any client via HTTP
OS visible	Yes	Yes	No
Scaling	Manual resize	Auto	Auto (unlimited)
Cost	Medium	Higher	Lowest
Use case	OS, DB volumes	Shared web content, CMS	Backups, media, data lake

Interview Q&A; — Storage

★★★★■

■ How do you increase EBS IOPS without downtime?

■ Use Elastic Volumes — modify the volume type or IOPS while it's in use. For gp2→gp3: you can increase IOPS independently from storage size. The change applies gradually without detaching. Monitor CloudWatch EBS metrics (VolumeReadOps, VolumeWriteOps) to confirm improvement.

■■ **TRAP: EBS snapshots are incremental but restoring creates a new full volume. The first snapshot is always full; subsequent ones only store changes. But you only need the latest snapshot to restore — AWS handles chain internally.**

Chapter 14: Security, KMS & Compliance

Encryption · KMS · Secrets Manager · Shield · WAF · GuardDuty

Encryption in AWS

Service	Encryption Option	Key Management
S3	SSE-S3, SSE-KMS, SSE-C, CSE	AWS or Customer
EBS	AES-256 via KMS at creation	KMS CMK
RDS	At-rest (KMS) + In-transit (TLS)	KMS CMK
Lambda	Env vars encrypted via KMS	KMS CMK
SQS	SSE via KMS	KMS CMK

KMS Key Types

- AWS Managed Keys: created/managed by AWS for each service. You can't rotate manually.
- Customer Managed Keys (CMK): you create, control, rotate, set policies. More flexibility.
- Data Keys: generated by KMS, used for envelope encryption of large data (KMS itself encrypts small payloads only).

Security Services Quick Reference

Service	What It Does
GuardDuty	Threat detection — analyzes VPC Flow Logs, CloudTrail, DNS logs using ML
Security Hub	Aggregates findings from GuardDuty, Inspector, Macie into one dashboard
Macie	Discovers and protects sensitive data (PII, credentials) in S3
Inspector	Automated vulnerability scanning for EC2, ECR images, Lambda
Shield Standard	Free DDoS protection for all AWS customers
Shield Advanced	Enhanced DDoS, 24/7 DRT access, cost protection — \$3000/mo
WAF	Web Application Firewall — block SQL injection, XSS, IP rules, rate limits

Interview Q&A; — Security

★★★★★

■ What is Envelope Encryption?

■ KMS generates a Data Encryption Key (DEK). You use the DEK to encrypt your data (fast, large data). Then KMS encrypts the DEK using a CMK. You store the encrypted DEK alongside the encrypted data. To decrypt: call KMS to decrypt the DEK, then use DEK to decrypt data. This keeps large data processing fast while KMS remains the root of trust.

★★★★■

■ Secrets Manager vs Parameter Store?

■ Secrets Manager: auto-rotates credentials (RDS, Redshift, custom Lambda rotation). Cross-account access. Costs \$0.40/secret/mo. Use for DB passwords, API keys requiring rotation. Parameter Store: free tier for Standard (up to 4KB, 10k params). Advanced tier for larger, higher throughput. No built-in rotation. Use for config values, non-secret parameters, or cost-sensitive secrets.

Chapter 15: Well-Architected & Cost Optimization

5 Pillars · Cost Tools · Trusted Advisor

Well-Architected Framework — 6 Pillars

Pillar	Key Principle	Example
Operational Excellence	Run and monitor, improve processes	IaC, runbooks, small frequent changes
Security	Protect data, systems, assets	Least privilege, encryption, MFA
Reliability	Recover from failure, meet demand	Multi-AZ, backups, auto scaling
Performance Efficiency	Use resources efficiently	Right-sizing, serverless, caching
Cost Optimization	Avoid unnecessary costs	Reserved, Spot, lifecycle policies
Sustainability	Minimize environmental impact	Right-sizing, efficient code

Cost Optimization Techniques

- Right-Sizing: use AWS Compute Optimizer recommendations to downsize idle EC2/RDS.
- Reserved Instances / Savings Plans: 30-72% savings for committed workloads.
- Spot Instances: up to 90% off for fault-tolerant batch and CI/CD jobs.
- S3 Lifecycle Policies: auto-tier data to Glacier after N days.
- Auto Scaling: scale down during off-hours, don't pay for idle capacity.
- Data Transfer: use VPC endpoints to avoid NAT Gateway data charges. S3 egress is expensive.
- AWS Cost Explorer + Budgets: track and alert on spend by service, tag, account.

Chapter 16: Top 60 Tricky Interview Questions & Answers

■ Must-Know for Any AWS Interview

★★★★★

■ Can an S3 bucket be accessed from a private subnet without going through the internet?

■ Yes. Create a VPC Gateway Endpoint for S3. Traffic routes through AWS internal network via route table — no NAT Gateway, no internet. This also eliminates NAT Gateway data processing charges for S3 traffic.

★★★★★

■ What is the difference between an SQS Standard Queue and FIFO Queue?

■ Standard: unlimited throughput, at-least-once delivery (rare duplicates), best-effort ordering. FIFO: exactly-once processing, strict order preserved, 300 TPS (3000 with batching). Choose FIFO only when order and deduplication are critical — it costs more.

★★★★★

■ How do you give an EC2 instance access to S3 without hardcoding credentials?

■ Attach an IAM Instance Profile (role) to the EC2 instance. The AWS SDK automatically retrieves temporary credentials from the instance metadata endpoint. Never store access keys on EC2 — they can be leaked via metadata if IMDS v1 is enabled.

★★★★★

■ What is IMDS v2 and why is it more secure than v1?

■ IMDSv2 requires a session token obtained via PUT request before GET requests for metadata. This blocks SSRF attacks — a web app exploited by SSRF cannot simply curl the metadata endpoint. Best practice: enforce IMDSv2 at account level using SCP and EC2 launch template settings.

★★★★★

■ How would you architect a multi-region active-active setup?

■ Use Route 53 Latency/Geolocation routing to distribute users to nearest region. Use Aurora Global Database (sub-1s replication) or DynamoDB Global Tables (multi-master). S3 Cross-Region Replication for static assets. Separate CloudFront distributions. Key challenge: write conflict resolution in multi-master databases.

★★★★■

■ What is the difference between horizontal and vertical scaling?

■ Vertical: increase instance size (more CPU/RAM). Has limits, requires downtime. Horizontal: add more instances behind a load balancer. Preferred — scales to demand, no downtime, more resilient. AWS Auto Scaling implements horizontal scaling.

★★★★■

■ How do CloudFront and S3 work together for a static website?

■ S3 hosts the files. CloudFront sits in front as CDN — caches content at edge locations worldwide. Use OAC (Origin Access Control) so S3 bucket blocks direct public access — only CloudFront can read it. Set cache behaviors, custom error pages, and HTTPS at CloudFront level.

★★★★■

■ What is the difference between RTO and RPO?

■ RTO (Recovery Time Objective): maximum acceptable downtime — how quickly must we recover? RPO (Recovery Point Objective): maximum acceptable data loss — how much data can we afford to lose? Design DR strategy around these. Pilot Light = low cost/high RTO. Multi-region active-active = low RTO/RPO, high cost.

★★★★★

■ **What happens to an RDS instance in a Multi-AZ setup during a failover?**

■ AWS automatically updates the DNS CNAME to point to the standby in ~60-120 seconds. Your app must handle connection retries — the hostname stays the same but the underlying IP changes. Use connection pooling (RDS Proxy) to absorb the brief disruption.

★★★★★

■ **What is the difference between AWS Config and CloudTrail?**

■ CloudTrail: audit log of API calls — who did what, when. AWS Config: tracks resource configuration over time — what does a resource look like NOW vs BEFORE. Config also enforces compliance rules. Example: CloudTrail tells you someone changed an S3 bucket policy; Config tells you the bucket was previously public.

★★★★■

■ **How does ElastiCache improve application performance?**

■ ElastiCache (Redis or Memcached) stores frequently accessed data in memory, reducing load on RDS. Redis: persistence, replication, Pub/Sub, Sorted Sets (leaderboards), Lua scripting. Memcached: simpler, multi-threaded, no persistence. Use caching for session store, DB query results, API responses.

★★★★■

■ **What is S3 Transfer Acceleration?**

■ Uploads to S3 are routed through the nearest CloudFront edge location via AWS backbone instead of public internet. Faster for clients far from the S3 region. Extra cost applies. Alternative for large transfers: AWS Snowball or multipart upload with S3.

★★★★★

■ **What is an AWS Organizations SCP?**

■ Service Control Policy: applies to all accounts in an OU or org. Sets the maximum permissions — even account admins can't exceed it. Used for guard rails: prevent disabling GuardDuty, restrict to allowed regions, block root user actions. SCPs don't grant permissions — they only restrict.

★★★★■

■ **How would you investigate a sudden spike in AWS costs?**

■ 1) Cost Explorer → group by service, then by resource. 2) Look at usage type — data transfer costs are common culprits. 3) Check Cost Anomaly Detection alerts. 4) Review CloudTrail for unexpected large-scale API calls. 5) Tag all resources and filter costs by team/project.

★★★★■

■ **What is the difference between NLB and ALB for internal microservices?**

■ ALB: for HTTP-based microservices — supports path-based routing, header-based routing, and gRPC. NLB: for non-HTTP (TCP/UDP) or when you need static IPs or extreme low latency (<1ms). For most microservices, ALB is the right choice. NLB works well as an entry point for on-premises connections.

★★★★★

■ **How do you secure an S3 bucket completely?**

■ 1) Enable Block Public Access at account + bucket level. 2) Use bucket policy with explicit Deny for non-HTTPS access (aws:SecureTransport). 3) Enable SSE-KMS encryption. 4) Enable S3 Versioning. 5) Enable S3 Access Logging. 6) Use VPC Endpoint for access from private subnets. 7) Enable Macie for sensitive data detection.

★★★★■

■ **What is AWS Config and how does it help with compliance?**

■ AWS Config records configuration state of resources and evaluates against Config Rules. Rules can be AWS-managed (e.g., 'S3 buckets should not be public') or custom Lambda-based. Non-compliant resources are flagged. Config Conformance Packs deploy multiple rules together (e.g., PCI-DSS, HIPAA). Integrates with Security Hub.

★★★★★

■ What is the Shared Responsibility Model?

■ AWS: security OF the cloud — hardware, data centers, network, hypervisor, managed service software. Customer: security IN the cloud — OS patches, application security, IAM configuration, data encryption, network rules, customer data. Managed services (RDS, Lambda) shift more responsibility to AWS; EC2 leaves more to the customer.

★★★★■

■ How does AWS handle availability zones?

■ Each region has 2-6 AZs. Each AZ is one or more data centers with independent power/networking/cooling. AZs are connected with low-latency, high-bandwidth links but isolated from each other's failures. Best practice: deploy across minimum 2 AZs for HA. AZ names (us-east-1a) map to different physical locations per account — preventing all customers from choosing the same AZ.

★★★★■

■ What is CloudFront signed URLs vs signed cookies?

■ Signed URL: grants access to a single object. Use for: individual file downloads, RTMP streaming. Signed Cookie: grants access to multiple files (entire content library). Use for: subscribed users accessing a whole video catalog. Both support expiration and IP restrictions.

Chapter 17: Production Scenarios & Troubleshooting

Real-World Problems AWS Engineers Face

Scenario: EC2 instance is unreachable via SSH

- Check Security Group: port 22 inbound from your IP?
- Check NACL: port 22 inbound AND ephemeral ports outbound?
- Check Route Table: correct route to IGW (public) or to VPN (private)?
- EC2 status checks: system (hardware) vs instance (software) failure?
- Use EC2 Session Manager (SSM) — no port 22 needed, no key pair required.
- If system check fails: stop→start (moves to new host). If instance check: reboot.

Scenario: RDS is slow — CPU at 90%

- Enable Performance Insights — identify top SQL statements.
- Check for missing indexes: look for full table scans.
- Review slow query log.
- Check connection count — connection storms exhaust CPU. Use RDS Proxy.
- Scale vertically (upgrade instance class) as temporary fix.
- Add Read Replica to offload read queries.
- Consider ElastiCache for frequent identical queries.

Scenario: S3 PUT requests returning 403 Forbidden

- Verify bucket policy doesn't have explicit Deny.
- Check Block Public Access settings — may block even authenticated writes.
- Verify the IAM role/user has s3:PutObject permission with correct resource ARN.
- Check bucket ACL if using pre-signed URLs (the signing entity needs permission).
- For cross-account: bucket policy must explicitly allow the other account.
- Check KMS key policy if SSE-KMS — the caller needs kms:GenerateDataKey.

Scenario: Lambda function timing out

- Increase memory (also increases CPU and network bandwidth).
- Check if Lambda is in VPC — cold start adds ~1s, and needs NAT for internet.
- Look for synchronous downstream calls that are slow — add timeout to HTTP clients.
- Check if Lambda is waiting on DynamoDB/RDS — they might be throttled.
- Enable X-Ray tracing to identify the slow segment.
- Check concurrency limits — throttled Lambdas queue up and exceed timeout.

Scenario: Auto Scaling Group not scaling out despite high CPU

- Check CloudWatch Alarm state — is it in ALARM?
- Check cooldown period — ASG may still be in cooldown from last scale.
- Check if max capacity is already reached.
- Verify the scaling policy is attached to the ASG and correct metric.
- Check that CloudWatch agent is running if using custom metrics.
- Ensure the new instances pass health checks — failed instances get terminated and recreated.

Scenario: DynamoDB returning ProvisionedThroughputExceededException

- This means requests are exceeding provisioned RCU or WCU.
- Short-term: implement exponential backoff + jitter in your client.
- Enable DynamoDB Auto Scaling to react dynamically.
- Analyze access patterns — are you hitting a hot partition key?
- Switch to On-Demand mode if traffic is very spiky.
- Add DAX (cache) to reduce read pressure.
- Redesign partition key if hot partition is the cause.

Scenario: CloudFormation stack stuck in UPDATE_ROLLBACK_FAILED

- This happens when rollback itself fails (e.g., trying to delete a resource that's already gone).
- In Console/CLI: use `ContinueUpdateRollback` — optionally skip specific resources.
- Identify which resource is blocking rollback from stack events.
- Manually fix the resource state (or delete it), then retry `ContinueUpdateRollback`.
- As last resort: contact AWS Support to force-skip problematic resources.

Scenario: High data transfer costs in AWS bill

- Check Cost Explorer → group by usage type → look for 'DataTransfer-Out-Bytes'.
- Common culprits: EC2 to internet, NAT Gateway, cross-region, cross-AZ traffic.
- Use VPC Endpoints for S3 and DynamoDB — eliminates NAT Gateway charges.
- Use CloudFront in front of origins — edge caching reduces origin data transfer.
- Keep traffic within same AZ when possible (cross-AZ has cost).
- Review CloudWatch metrics for data volume by resource.

Chapter 18: AWS Cheat Sheets

Quick Reference for Interview Day

Service Limit Quick Reference

Service	Limit	Adjustable?
EC2 On-Demand vCPUs	Per instance family, regional	Yes
Lambda concurrency	1,000 per region	Yes
S3 buckets	100 per account	Yes (up to 1000)
VPCs per region	5	Yes
SQS msg size	256KB	No (use S3 pointer)
DynamoDB item size	400KB	No
EBS gp3 IOPS	16,000	No (use io2 for more)
ALB rules	100 per listener	Yes
RDS max connections	Depends on instance class	Use RDS Proxy to pool

Key Ports to Remember

Port	Service
22	SSH
80	HTTP
443	HTTPS
3306	MySQL / Aurora MySQL
5432	PostgreSQL / Aurora PostgreSQL
1433	SQL Server
6379	Redis (ElastiCache)
11211	Memcached
2181	Zookeeper
9092	Kafka

DR Strategy Comparison

Strategy	RTO	RPO	Cost
Backup & Restore	Hours	Hours	Lowest
Pilot Light	10s of min	Minutes	Low
Warm Standby	Minutes	Seconds	Medium

Strategy	RTO	RPO	Cost
Multi-Site Active-Active	Near zero	Near zero	Highest

IAM Policy JSON — Quick Anatomy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["s3:GetObject"],
      "Resource": "arn:aws:s3:::my-bucket/*",
      "Condition": {
        "IpAddress": {
          "aws:SourceIp": "192.0.2.0/24"
        }
      }
    }
  ]
}
```

Key fields: Effect (Allow/Deny), Action (service:action), Resource (ARN), Condition (optional).

One-Line Definitions — Must Know

- **AMI**: Snapshot of EC2 including OS, apps, and config — used to launch instances.
- **EIP**: Elastic IP — static public IPv4 address you own; survives instance stop/start.
- **ENI**: Elastic Network Interface — virtual NIC; can be moved between instances.
- **Egress-Only IGW**: IPv6 outbound-only internet gateway for private IPv6 instances.
- **AWS Batch**: Run batch computing jobs on managed EC2/Fargate — auto provisions compute.
- **Step Functions**: Serverless workflow orchestration using state machines — sequence Lambda, ECS, etc.
- **Cognito**: User authentication (User Pools) and AWS resource access (Identity Pools).
- **ACM**: AWS Certificate Manager — free TLS/SSL certificates for ALB, CloudFront, API GW.
- **Config Rule**: Evaluates AWS resource compliance against a policy automatically.
- **Trusted Advisor**: Recommends cost savings, performance improvements, security fixes, and service limits.

★ FINAL INTERVIEW TIP ★ When answering any AWS question, structure your answer as: (1) What it is, (2) Why/when you use it, (3) Key trade-offs or gotchas, (4) Real example from production or a project. This 4-part pattern signals an experienced engineer regardless of the specific topic.